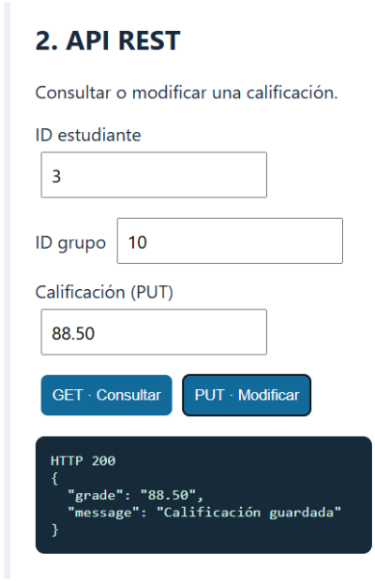
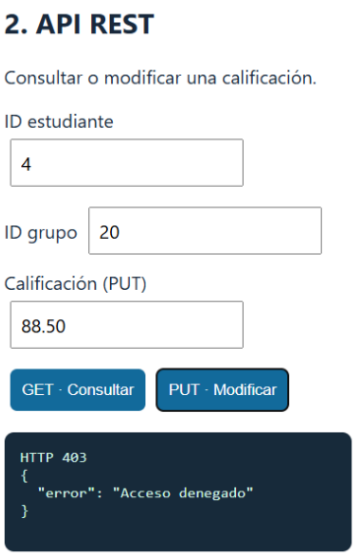
LABORATORIO 07

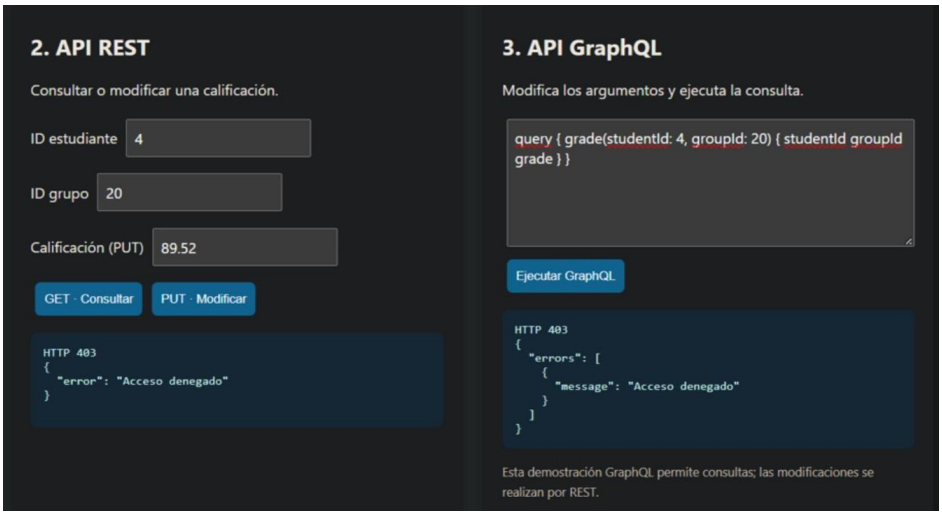
(a) captura de la interfaz REST con 200

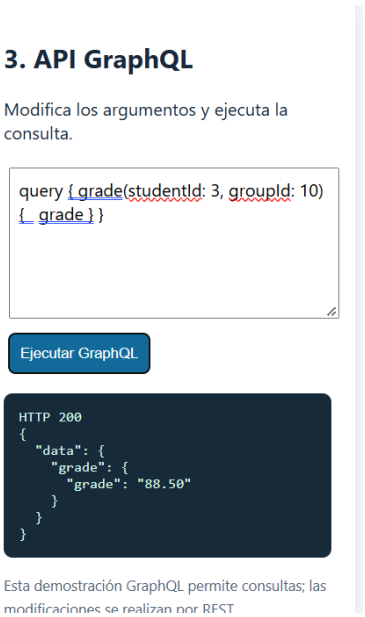


(b) captura de REST con 403



(c) captura de GraphQL con 200 y 403





(d) captura del resultado pytest



(e) respuestas de las preguntas de reflexión.

¿Qué significa 200, 400, 401 y 403?

- 200 (OK): Indica que la solicitud del cliente se procesó y completó con éxito por parte del servidor.
- 400 (Bad Request): Significa que la solicitud contiene errores de sintaxis, formato o parámetros inválidos por parte del cliente.
- 401 (Unauthorized): Indica que falta autenticación; el usuario no ha iniciado sesión o sus credenciales no son válidas.
- 403 (Forbidden): Significa que el servidor entiende quién hace la solicitud (el usuario está autenticado), pero le niega el acceso al recurso por falta de privilegios o permisos.

¿Qué diferencia existe entre iniciar sesión y tener autorización?

La autenticación (iniciar sesión) comprueba quién es el usuario mediante credenciales (usuario y contraseña). La autorización determina qué acciones, datos o recursos específicos tiene permitido consultar o modificar ese usuario según su rol o grupo asignado dentro del sistema.

¿Por qué una persona no debe poder consultar calificaciones de otros estudiantes cambiando los identificadores?

Para proteger la confidencialidad, privacidad e integridad de los datos académicos. Permitir esto facilitaría vulnerabilidades de tipo IDOR (Insecure Direct Object References), exponiendo información sensible de terceros con solo alterar parámetros numéricos en la URL o en las solicitudes de la API.

¿Qué cambia al consultar una calificación por REST o por GraphQL?

En REST, el punto final (endpoint) y la estructura de los datos están fijos en la ruta establecida por el servidor. En GraphQL, el cliente tiene la flexibilidad de indicar explícitamente los campos exactos que desea recibir en su consulta, optimizando el intercambio de información, aunque ambos modelos deben validar estrictamente los permisos en el servidor.

¿Qué pasaría si GraphQL omitiera la comprobación de permisos?

Cualquier usuario o atacante podría explotar la flexibilidad de consultas de GraphQL para extraer masivamente información confidencial (como calificaciones o datos de otros grupos) con solo solicitar dichos campos en la estructura de la consulta, vulnerando por completo la seguridad de la aplicación.